北京市“两节两营”科技冬令营课程方案（口令攻防模块 · 两天）

奇安信：新一代网络安全领军者

To build is to understand; To break is to secure.

口令攻防模块负责人（草案）

2025 年 12 月 17 日

模块定位与原则

- **面向对象**：初中为主（可混编高中生担任小组助教/记录员）；学生默认**无密码学基础**、无攻防经验。
- **模块位置**：7 天课程中的第 3–4 天（两天），承接第 1–2 天的“个人建站”成果（每组已有可访问的练习站点/登录页）。
- **核心主线**：从**在线暴力尝试**的直观风险出发，理解验证码/人机验证/限速/锁定的意义；第 2 天扩展到**个性化口令猜测**（TarGuess-i，PCFG-based），最后**简提** LLM 带来的新风险。
- **安全边界**：所有攻击演示仅限**本地/课堂内网靶场**，使用**虚构账号与口令空间**（例如 4 位 PIN 或极小字母表），**不**教授/不布置通用化的外网攻击。
- **评价方式**：以**过程性考核**为主（理解、记录、解释、复现与改造），结果性考核为辅（功能是否生效、对比是否完整）。

1 学习目标（Learning Outcomes）

知识目标

- 说清楚 HTTPS/证书的作用：**身份认证**与**传输加密**分别解决什么问题。
- 理解最小密码学概念：**哈希**（不可逆指纹）、**加盐**（避免相同口令产生相同指纹）、**慢哈希**（提升离线猜测成本）。
- 理解在线口令猜测的核心特征：**短时间大量失败请求**与**搜索空间**。
- 理解 PCFG/TarGuess-i 的直观思想：**结构/模式 + 概率排序**；知道它与“纯暴力”的差别。

技能目标

- 能运行给定的演示脚本/工具并解读输出（尝试次数、速率、命中位置）。
- 能对练习网站实现至少 1 项防护改造（验证码/人机验证概念、限速、失败锁定、延迟退避、简化二步验证等）并完成复测对比。
- 能基于人物画像列出 Top20 口令候选并总结常见模式，再与 TarGuess-i 输出进行对比分析。

态度与意识

- 形成 "**理解攻击才能设计防御**" 的工程思维；能在安全与可用性之间做解释性取舍。
- 形成对 "公开个人信息 → 个性化猜测风险" 的警觉，能提出可执行的个人与系统防护建议。

2 课程组织与资源

2.1 组织方式（建议）

- 班级 300 人建议按 **4–6 人/组**分组；每组设置：组长、开发、测试、记录员（高中生可优先担任测试/记录/助教）。
- 统一发放 "练习站点项目"（Flask 示例）、人物卡、实验记录表（纸质或在线表单）。

2.2 软硬件资源

- 学生端：浏览器、Python 环境（建议 3.10+）、IDE（任选：VS Code / PyCharm Edu / Thonny），命令行基础操作（进入目录、运行脚本）。
- 教师端：投影、可控靶场网络（本地/内网）、预先准备的演示脚本（在线尝试）、TarGuess-i 运行环境与示例数据。
- 练习站点：提供带登录页的 Flask 小站（例如本项目），可快速启动与修改。

3 两天总流程与时间建议

总览（可按实际压缩/拉伸）

日程	环节	内容与产出
Day 1	环节 0：基础科普	HTTPS/证书、最小密码学概念、口令策略；产出：口令规则卡（小组版）

日程	环节	内容与产出
Day 1	环节 1：在线爆破与防护	教师演示在线暴力尝试；学生完成验证码/人机验证概念、限速/锁定等改造并复测；产出：前后对比记录
Day 2	环节 2：个性化猜测	人物画像猜口令 Top20；总结模式；运行 TarGuess-i 并对比命中排名；产出：模式清单 + 对比分析
Day 2	扩展：LLM 与离线	10–20 分钟：LLM 猜测趋势、离线攻击概念（闲谈）；产出：2 条个人建议 +2 条系统建议

4 Day 1：基础知识 + 在线爆破与防护改造

4.1 环节 0（科普）：HTTPS/证书与最小密码学

基础知识要点（讲义结构建议）

- **问题 1：口令在路上会发生什么？**
  浏览器 → 网络 → 服务器。没有 HTTPS 时可能被**窃听**（看见你输入）或**篡改**（把你导向假网站）。
- **证书是什么？**
  证书像“网站身份证”：让浏览器确认“你连的是对的那个网站”（身份认证）。
- **TLS/HTTPS 解决什么？**
  TLS 建立加密通道：解决**传输机密性**与**完整性**，让旁路的人看不懂也改不了。
- **问题 2：服务器怎么保存口令才不危险？**
  口令不能明文保存。理想做法：保存**哈希**（不可逆）、加**盐**（每人不同）、使用**慢哈希**（让离线猜测变慢）。
- **问题 3：好口令长什么样？**
  长度优先（建议 ≥ 12 字符）、不绑定明显个人信息、不复用、重要账户开启 MFA。

小活动 0A：“看一眼证书”（5–10 分钟，非必需）

原理 浏览器会展示 HTTPS 连接的证书信息：签发给谁、由谁签发、有效期等。证书异常会出现警告。

步骤

1. 打开任意 HTTPS 站点（可用校内门户或示例站），点击地址栏锁形图标查看证书。
2. 观察证书的**域名**、**有效期**、**签发机构**。
3. 讨论：如果证书域名不匹配或过期，可能意味着什么风险？

过程考核点 学生能用一句话解释：证书主要解决“_____”问题（身份认证）。

小活动 0B：口令强度与“搜索空间”（10–15 分钟）

原理 口令越长、可用字符越多，暴力尝试需要的组合数就越大。课堂只需用直觉理解数量级变化（不要求计算对数）。

步骤

1. 教师给出三种口令规则（示例）：4 位数字 PIN、8 位小写字母、12 位混合字符。
2. 学生只做“更大/更小”比较：哪种最容易被试出来？为什么？
3. 小结：**长度优先**通常比“加几个符号”更关键。

过程考核点 学生能解释：把口令长度从 8 提高到 12，在线爆破难度会_____（显著上升）。

4.2 环节 1（主实验）：在线口令爆破演示 + 防护改造

4.2.1 实验 1：在线暴力尝试（教师演示为主，学生观察记录）

实验目的 让学生理解“在线爆破”的本质：对登录接口做大量重复尝试；理解**搜索空间**与**尝试速率**决定风险。

实验原理（讲给学生的版本） 把口令看作一把钥匙。如果钥匙只有 4 位数字（0000–9999），攻击者可以按顺序试：试的速度越快、口令越短，就越容易被撞中。
在线爆破的特征是：同一账号（或同一 IP）出现**短时间大量失败登录**。

实验准备（教师）

- 启动练习站点（本地/内网），准备一个演示账号（虚构），口令设置为**小空间**（例如 4 位 PIN 或极简字符集）。
- 准备演示脚本：向`/login`连续发送请求（受控速率、受控总次数）。
- 明确课堂规则：禁止对外网、禁止对同学账号；只对老师提供的靶站与靶账号测试。

演示脚本安全约束（建议写进课堂规则）

- 仅允许访问课堂靶站的域名/IP 白名单；禁止任意 URL 输入。
- 速率上限：例如 ≤ 5 次/秒（保证网络与服务稳定）。
- 总次数上限：例如 ≤ 2000 次；达到上限必须自动停止。
- 口令空间上限：仅允许 PIN 或极小字符集，避免把课堂变成“真实破解训练”。

步骤（课堂执行）

1. 教师投影展示：正常手动登录一次（说明登录入口与参数）。
2. 教师运行演示脚本：以小口令空间进行尝试，直到命中或达到次数上限。

3. 学生填写观察表：记录尝试总数、用时、平均速率、命中位置（第几次）。
4. 全班讨论：把口令长度从 4 位提升到 6 位，风险变化会是什么量级?

学生记录表（实验 1）

字段	填写内容
口令空间假设	例如：0000–9999（共 10000 种）
尝试上限	例如：500 次 / 2000 次
实际用时	_____
平均速率（估算）	_____ 次/秒
是否命中	是 / 否
命中位置（第几次）	_____
风险一句话结论	_____

4.2.2 实验 2：防护改造（小组动手）

实验目的 把“能被爆破”的登录系统改造成“不容易被自动化尝试”：让攻击**变慢、变贵、变不可持续**。

实现提示（以 Flask 练习站为例，面向学生的任务拆解） 以下是推荐的实现拆解（不要求一次做全，可按小组能力选做）：

- **状态记录**：为“账号”或“IP”维护登录失败计数与最后失败时间（可先用内存字典，强调课堂演示即可）。
- **阈值策略**：定义阈值 N 与锁定时长 T；超过阈值则拒绝登录并提示剩余时间。
- **挑战机制**：失败次数达到 k 后才出现验证码/算术题（降低正常用户负担）。
- **可观测性**：把登录事件写入简单日志（时间、账号、成功/失败、触发了什么限制），用于复盘。

若使用本仓库示例项目，可直接在 `app.py` 与 `templates/login.html` 中完成最小改造（教师可提供起始模板文件，避免学生从零写）。

实验原理（分层解释）

- **验证码/人机验证**：让每次尝试需要人类参与或更高成本的识别，从而抑制自动化。
- **限速/延迟**：每次失败增加等待，让单位时间尝试次数下降。
- **失败锁定**：失败次数超过阈值后短暂锁定账号或要求更强验证。
- **（可选）简化二步验证**：即使口令被猜中，还需要第二个因素才能登录成功。

任务分级（每组选做，推荐至少完成 A）

A. 失败次数阈值 + 临时锁定（推荐）

例如：同一账号连续失败 3 次，锁定 60 秒，期间不再处理登录尝试。

B. 失败后延迟/退避（推荐）

例如：每次失败增加 1 秒等待，最多增加到 5 秒（演示 “爆破变慢”）。

C. 验证码（推荐）

使用课堂可实现的简单形式：算术题/拼图验证码/一次性图片码（不追求工业强度，追求原理）。

D. 人机验证/Cloudflare 概念展示（讲解型）

说明网关层如何做风控：指纹、速率限制、挑战页面。若课堂环境无法真正接入 Cloudflare，可用 “模拟网关” 规则展示思想。

E.（挑战）简化二步验证

登录口令正确后再输入一次性码（教师发放/小组共享密钥生成），或回答预设安全问题（强调缺点：安全问题易被猜）。

步骤（学生）

1. 阅读项目的登录流程：前端表单 → 后端`/login` 校验 → 写入 session。
2. 选择任务 A–E 之一，完成代码改造与自测。
3. 填写 “防护设计说明”：**我在对抗哪种特征？**（高频失败/自动化/重复尝试）
4. 由教师或助教用同一演示脚本进行复测，学生记录前后对比。

小组提交物（实验 2）

- 防护点说明（1 页以内）：做了什么、为什么有效、会带来什么副作用（可用性）。
- 复测对比表：改造前/后尝试速率、是否被锁定/是否需要验证码、成功率变化。

复测对比表（实验 2）

指标	改造前	改造后
每秒尝试次数（估算）	_____	_____
达到阈值是否触发限制	否 / 是（_____）	否 / 是（_____）
是否需要验证码/挑战	否 / 是（类型：_____）	否 / 是（类型：_____）
攻击是否还能自动化	是 / 否（理由：_____）	是 / 否（理由：_____）
可用性影响	_____	

Day 1 过程考核表（教师/助教）

考核点	达成	备注
能解释证书/TLS 解决的两个问题（身份、加密）	☐	
能用自己的话解释“哈希 + 盐”的意义（概念级）	☐	
完成实验 1 观察记录（字段完整）	☐	
完成至少一项防护改造（A–E）并可演示	☐	
能说明所做防护针对的攻击特征与副作用	☐	

Day 1 小测（可选，5 题，10 分钟）

1. 证书主要用来解决什么问题?（A. 让网页更好看 B. 身份认证 C. 提升网速）
2. HTTPS 主要保护的是：A. 传输中的机密性/完整性 B. 电脑不被病毒感染 C. 账号永不泄露
3. 为什么不能把口令明文存数据库？请用一句话说明风险。
4. 在线爆破的两个关键量是什么?（提示：空间与速度）
5. 写出一种你能想到的登录防护策略，并写一句话解释它如何降低爆破成功率。

5 Day 2：人物画像猜口令 + TarGuess-i（PCFG）+ 简提 LLM

5.1 环节 2A：人物卡猜口令（人类直觉版）

目的 让学生体验“个性化猜测”：当攻击者知道一些个人信息时，猜口令会比纯暴力更“聪明”。

原理（直观版） 很多人会把口令写成“有意义的东西”：姓名/昵称、生日、学校缩写、喜欢的球星/游戏、常用数字等。攻击者会优先尝试这些“最可能”的组合。

步骤

1. 每组领取 2–3 张人物卡（虚构信息），每张卡对应一个“目标账号”（仅课堂使用）。

2. 对每个角色，写出 Top20 候选口令并排序（最可能 → 最不可能），同时标注模式（如：姓名拼音 + 生日）。
3. 全班汇总：把共通模式写在白板上，讨论哪些模式最常见、为什么。

小组输出 Top20 清单（含排序理由）+ 共通模式清单（至少 5 条）。

5.2 环节 2B：TarGuess-i（PCFG-based）运行与对比

目的 让学生看到“统计模型”如何把“模式”变成**概率排序**，并在同样信息下生成更系统的候选列表。

原理（课堂版，不讲公式）

- TarGuess-i 把口令拆成“结构”（例如：字母段 + 数字段 + 符号）与“填空”（把姓名、生日、爱好等填入结构）。
- 它从大量真实口令中学习：哪些结构更常见、哪些组合更常被人使用，于是得到一个“更可能先试”的顺序。
- 所以它不是随机试，而是**先试最可能的那批**。

实验准备（教师）

- 已配置好的 TarGuess-i 代码与运行脚本（你已准备）。
- 人物卡信息对应的输入格式（例如 JSON/CSV/文本模板）。
- 预先为每张人物卡设置一个“目标口令”（仅用于课堂测评），并确保口令遵循可解释的习惯（而非纯随机）。

步骤（学生跟做，教师带跑）

1. 学生把人物卡信息录入 TarGuess-i 所需格式（或直接使用教师提供的输入文件）。
2. 运行 TarGuess-i 生成 Top-N 候选（建议 $N = 100$ 或 500，按课堂节奏调整）。
3. 查找目标口令在候选中的排名（第几位），并记录。
4. 对比分析：TarGuess-i 的 Top20 与人类 Top20 有多少重合？它新增了哪些模式？

对比分析表（Day 2）

项目	人类 Top20	TarGuess-i Top-N
目标口令是否出现	是 / 否	是 / 否
若出现，排名	_____	_____
主要模式（举 3 条）	_____	_____

项目	人类 Top20	TarGuess-i Top-N
新增/意外模式（举 2 条）	—	_____
结论一句话	_____	

5.3 环节 2C：简提 LLM 与风险升级（10–20 分钟）

讲解要点（只讲趋势）

- 传统统计模型擅长“结构 + 概率”；大模型可能更擅长从公开文本中学会“更像人写的表达”与梗。
- 结论回到防御：不要把口令和可公开的个人信息强绑定；重要系统启用 MFA；系统侧要做限速、锁定、风控与监控。

课堂互动（可选，10 分钟）

- 问题 1：如果一个人的公开信息越多，个性化猜测会变得更容易还是更难？为什么？
- 问题 2：“为了好记，把口令设成自己昵称 + 生日”有什么问题？给出更好的替代方案。
- 问题 3：当系统强制很复杂的口令规则时，会带来哪些可用性问题？如何折中（例如密码管理器、MFA）？

5.4 Day 2 汇报与展示（建议 20–30 分钟）

- 每组用 1 页纸或 1 张幻灯片汇报：Top20 模式总结、TarGuess-i 命中排名、“我会如何改进口令策略/登录流程”。
- 教师点评维度：模式是否合理、解释是否清晰、建议是否可执行、是否体现安全与可用性的权衡。

Day 2 过程考核表（教师/助教）

考核点	达成	备注
能总结至少 5 条常见口令模式并举例	☐	
完成人物卡 Top20 排序且理由可解释	☐	
能正确运行 TarGuess-i 并找到目标口令排名	☐	
能解释 TarGuess-i 与纯暴力的差别（排序/概率）	☐	

考核点	达成	备注
能提出 2 条个人建议 +2 条系统建议（LLM 时代）	□	

6 评分建议（可直接落到过程考核分）

小组得分（建议 60 分）

项目	分值	评分要点
实验 1 观察记录完整	10	字段齐全、能解释空间与速率
防护改造实现与演示	25	至少 1 项可运行；触发条件清晰；提示信息合理
复测对比与结论	15	前后对比数据可信；能说清楚为何变慢/变难
Day2 对比分析（人类 vs TarGuess）	10	有 Top20、排名、模式总结与反思

个人得分（建议 40 分）

项目	分值	评分要点
课堂参与与分工履职	10	有实际贡献（开发/测试/记录/汇报）
概念理解（口头或小测）	20	能解释 HTTPS/哈希/在线爆破/防护逻辑
反思与建议	10	能给出可执行的个人与系统建议

7 过程考核表（可打印总表）

E0：助教巡检记录（每组一张）

时间	巡检对象	当前进度	问题与指导建议
_____	第____ 组	☐ 理解完成 ☐ 编码中 ☐ 自测中 ☐ 待复测	_____
_____	第____ 组	☐ 理解完成 ☐ 编码中 ☐ 自测中 ☐ 待复测	_____
_____	第____ 组	☐ 理解完成 ☐ 编码中 ☐ 自测中 ☐ 待复测	_____

E1：小组汇报评分表（每组一张）

维度	分值	得分
表达清晰：能用通俗语言讲清楚做了什么与为什么有效	10	_____
证据充分：有前后对比数据/现象支撑结论	10	_____
工程性：触发条件清晰、提示信息合理、考虑副作用	10	_____
反思深度：能指出至少 1 个仍存在的风险与改进方向	10	_____

E2：个人参与与反思（每人一张，课后 5 分钟）

- 我在小组中的角色：☐ 开发 ☐ 测试 ☐ 记录 ☐ 汇报 ☐ 组长/协调
- 我本次贡献的具体工作(写一句话):_____
- 我学到的最重要的 1 个概念：_____
- 我对自己的账号口令习惯准备做的 1 个改变:_____
- 我对网站登录系统的 1 条改进建议:_____

8 （扩展闲谈）离线攻击：什么时候会发生?

一句话解释 **离线攻击**是攻击者拿到了口令的“校验物”（通常是哈希）后，在自己电脑上无限次猜测；此时验证码/Cloudflare 对他几乎无效，因为他不再访问你的网站。

课堂可讲的判断法 如果攻击者**只有登录页面**、只能对`/login`发请求：这是**在线**。
如果攻击者拿到了**数据库备份/用户表哈希/日志泄露的哈希**：才可能做**离线**。

9 教师备课清单（建议）

- 练习站点可一键启动；所有账号与口令均为虚构，且口令空间受控（课堂安全）。
- 在线尝试演示脚本可控速率、可控次数，带“停止开关”。
- 预设人物卡 × 若干套（建议至少 6 种画像，便于轮换防止泄题）。
- TarGuess-i 运行环境已验证：输入 → 输出稳定；准备一份“标准输出样例”以防现场故障。
- 打印：实验 1 观察表、实验 2 对比表、Day2 对比分析表、过程考核表。

10 课堂安全与合规声明（建议投影并由学生确认）

- 我承诺：只在老师提供的课堂靶场上进行测试，不测试外网网站与他人账号。
- 我承诺：不传播、不保存真实账号口令；所有实验账号均为虚构或一次性。
- 我理解：本课程目的是学习防护设计与安全意识，任何超出课堂授权的测试都可能违法违规。

A 附录 A：人物卡模板（示例，可自行扩展）

人物卡 1（示例）

- 昵称：LinLin 真实姓名（可选）：林某某
- 年级：初二 学校简称：THS
- 生日：2011-08-16 喜欢的数字：16、8
- 爱好：篮球 喜欢的球星：Kobe
- 常用 ID：linlin16 常用口头禅：“冲冲冲”
- （教师私密）目标口令：_____

人物卡 2（示例）

- 昵称：Ming 学校简称：BJ
- 生日：2010-12-01 爱好：原神 常用 ID：ming_paimon
- 喜欢的数字：1201 喜欢的词：“wind”
- （教师私密）目标口令：_____

人物卡 3（示例）

- 昵称：Zoe　学校简称：QHFZ
- 生日：2009-03-07　爱好：摄影　口头禅：“今天也要出片”
- 喜欢的数字：37　常用 ID：zoe_photo37
- 喜欢的词：“light”、“lens”
- （教师私密）目标口令：_____

人物卡 4（示例）

- 昵称：Kai　学校简称：BJ
- 生日：2011-11-11　爱好：街舞　喜欢的组合：“KDA”
- 喜欢的数字：1111　常用 ID：kai_dance11
- （教师私密）目标口令：_____

人物卡 5（示例）

- 昵称：HaoHao　学校简称：THS
- 生日：2010-06-18　爱好：编程　常用 ID：haohack618（注意：虚构）
- 喜欢的词：“debug”　喜欢的数字：618
- （教师私密）目标口令：_____

人物卡 6（示例）

- 昵称：Yuki　学校简称：QAX
- 生日：2008-09-09　爱好：二次元　喜欢的角色名：“Asuna”
- 常用 ID：yuki_asuna_99　喜欢的数字：99
- （教师私密）目标口令：_____

B　附录 B：口令模式清单（课堂引导用）

可引导学生从下列方向总结模式（避免直接给答案，可先让学生总结后再补充）：

- 姓名/昵称拼音 + 年份/生日（全/后两位）
- 学校缩写 + 数字（年级/班级/生日片段）
- 爱好/偶像 + 数字（球衣号/纪念年份）
- ID 复用（把用户名直接当口令，或轻微变体）
- “词 + 词 + 数字”、“词 + 符号 + 数字”（增加可记忆性）

C 附录 C：可压缩版时间安排（示例）

若每一天仅有 3 小时，可按以下压缩：

- Day1：科普 30min + 在线爆破演示 20min + 防护改造 90min + 复测与总结 40min
- Day2：人物卡猜测 40min + TarGuess-i 对比 70min + LLM/离线闲谈 20min + 汇报与评价 50min

D 附录 D：工作纸模板（可直接打印）

D1：人物卡 Top20 候选表

#	候选口令（示例写法）	理由/模式标注（如：昵称 + 生日后四位）
1		
2		
3		
4		
5		
6		
7		
8		
9		
10		
11		
12		
13		
14		
15		
16		
17		
18		
19		
20		

D2：防护设计说明（1 页模板）

- 我们选择的防护（勾选）：☐ 锁定 ☐ 延迟/退避 ☐ 验证码 ☐ 简化 2FA ☐ 其他：_____

- 要对抗的攻击特征(至少 1 条): _____
- 触发条件(阈值 N、时长 T 等): _____
- 对正常用户的影响(可用性副作用): _____
- 我们的复测结果一句话: _____